HACKATHON / MOBILE SECURITY

ON-DEVICE
APP RISK AUDITOR

Turn Android permissions into clear, explainable risk.

Scan • Understand • Decide

ON-DEVICE | EXPLAINABLE | ACTIONABLE



Safer apps. Better decisions.

A privacy-first Android security concept

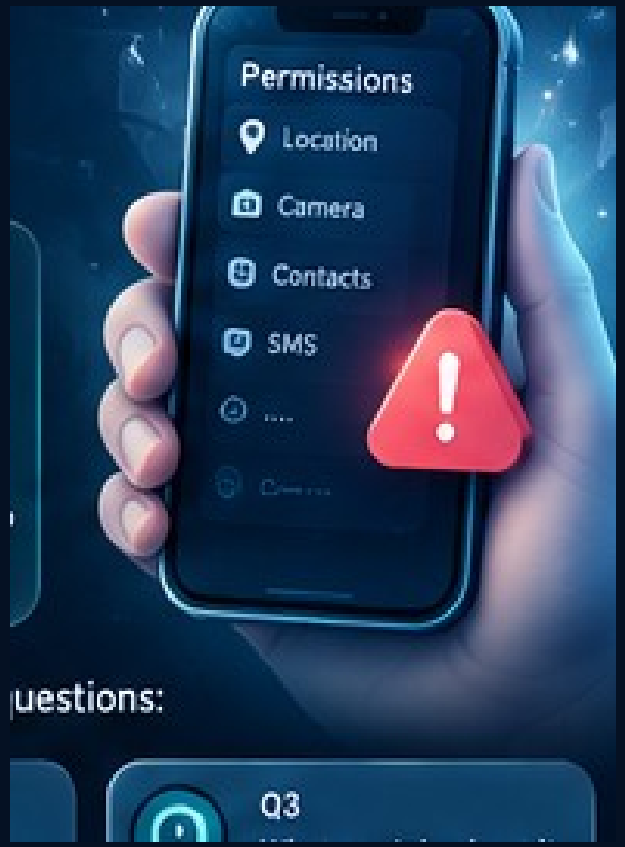
The problem: permissions don’t tell the whole story

People can see what an app requests, but not always what that access means in combination.

The user’s blind spot

- Permission lists are technical and hard to interpret.
- Special access can be more powerful than ordinary permissions.
- Risk often comes from combinations—not one permission alone.
- Users need a reason and a next step, not just a warning.

Core question: “Which app should I check first—and why?”



WHAT USERS NEED

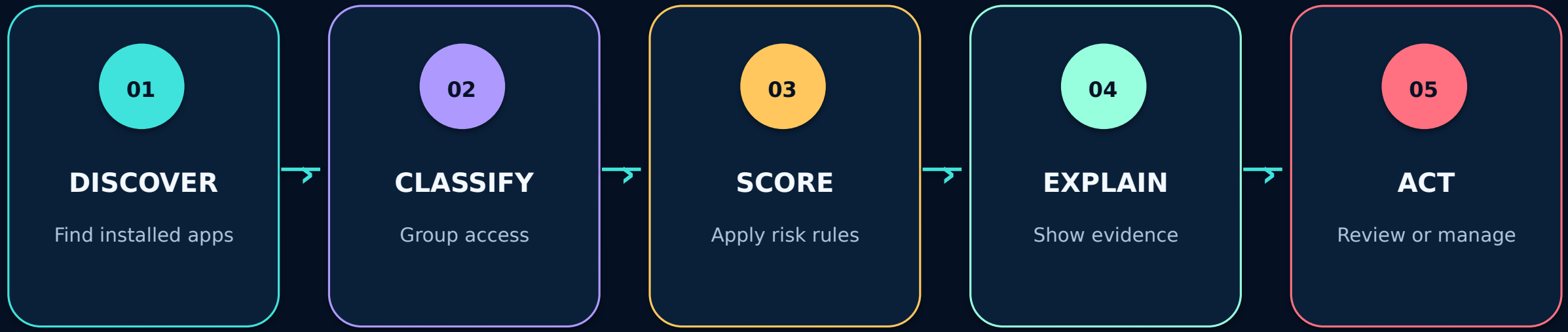
01 **Which app?**

02 **Why flagged?**

03 **What now?**

A simple flow. A clearer risk story.

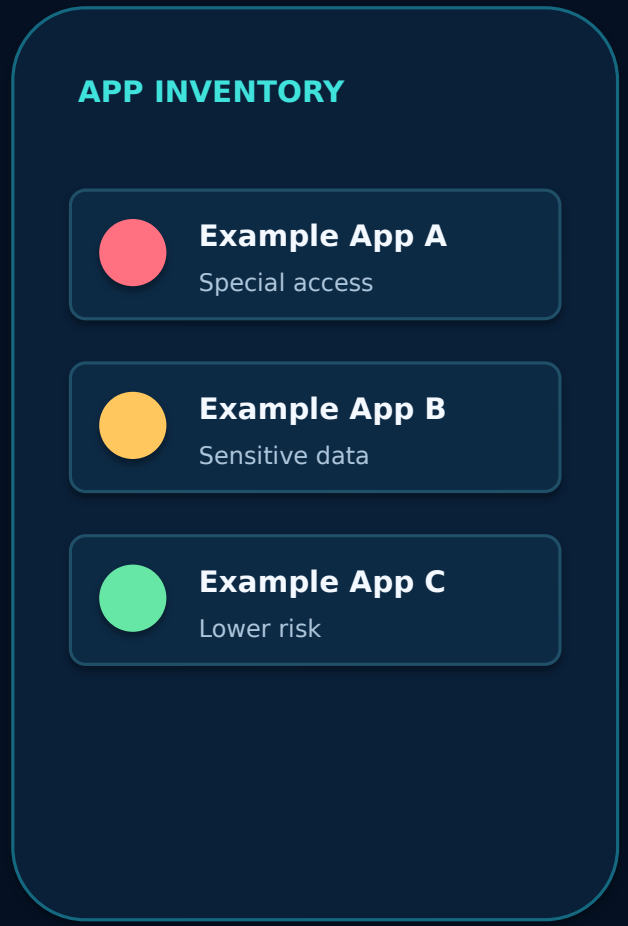
The auditor transforms technical access into evidence a non-technical user can act on.



Design principle **Every high-risk result should answer “why?” and suggest a reasonable next step.**

Inside the auditor: from scan to explanation

A modular pipeline makes the result understandable and easier to test.



1. **Scan installed apps** — Build a device app inventory.
2. **Extract access** — Read declared/granted permissions and special access where supported.
3. **Categorize** — Map signals to the nine categories.
4. **Analyze combinations** — Apply transparent rules and weights.
5. **Present evidence** — Show score, reasons, and suggested actions.

Important: exact visibility depends on Android version and access APIs.

Nine permission & access categories

The category map organizes signals; the actual risk depends on context and combinations.

01 — Special access
Accessibility • overlay • device admin

02 — SMS
Read / send SMS

03 — Contacts & calls
Contacts • call logs

04 — Camera & mic
Camera • record audio

05 — Location
Fine / background location

06 — Phone & identity
Phone state • identifiers

07 — Storage & media
Photos • files

08 — Background & persistence
Services • startup behavior

09 — Network
Internet / network state

Highest weight: special access. It can be powerful, but is not automatically malicious.

Explainable risk scoring

The score prioritizes review; the reasons help the user understand what drove it.



78 / 100

HIGH RISK • example only

Not a verdict—an explainable review priority.

RISK BANDS

0–25	LOW
26–50	MEDIUM
51–75	HIGH
76–100	CRITICAL

WHY WAS THIS APP FLAGGED?

01 Special access detected

02 Sensitive permissions appear together

03 Unfamiliar source or install context

04 Suggested next step: review app access

High / Critical results: show at least 3 human-readable reasons.

Privacy is part of the product

Security tooling should minimize the data it needs and make its behavior clear.



1 **ON-DEVICE**

Analyze locally where supported.

No app inventory sent to a server.

2 **OFFLINE-FIRST**

Core review should not depend on cloud access.

Works without an account or internet.

3 **MINIMAL ACCESS**

Request only the access needed to audit.

No root or ADB required from users.

4 **USER CONTROL**

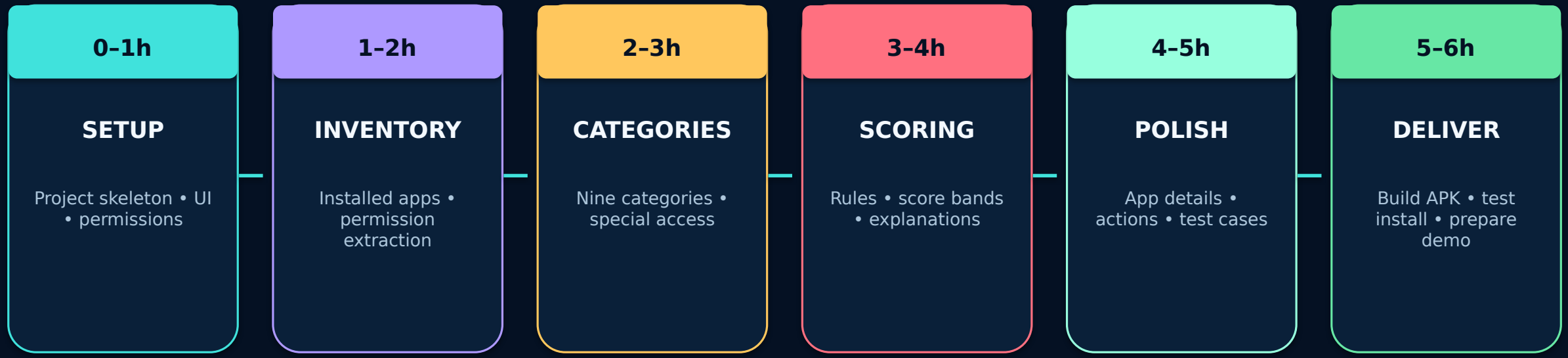
Explain before suggesting an action.

User chooses what to review or remove.

Privacy promise must match the actual implementation.

Six-hour development plan

Protect time for integration and a working APK—not only feature coding.

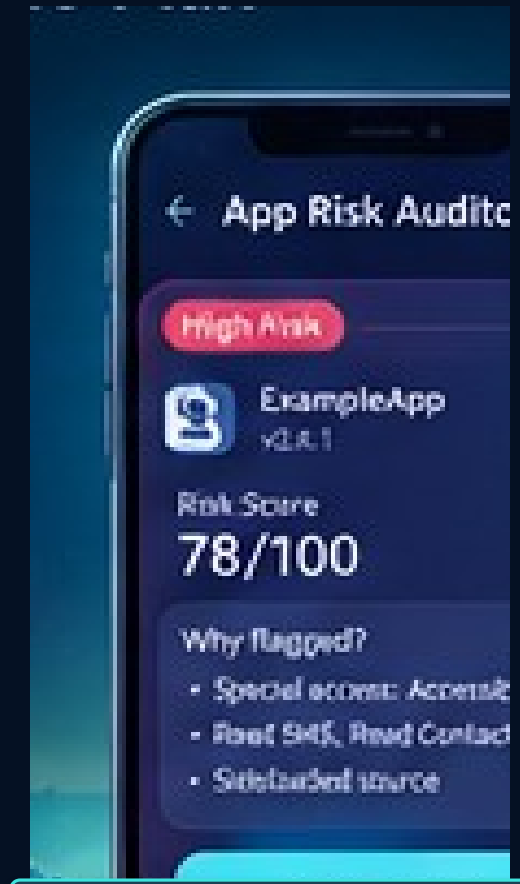


Milestone rule **By hour 5, install and launch the core APK. Use hour 6 for verification and demo readiness.**

Three-minute live demo

Use a prepared test device and one known example app; keep every step visible.

00:00–00:20	**INTRODUCE**	Show home screen and what is being audited.
00:20–00:50	**SCAN**	Run scan and show app inventory.
00:50–01:30	**EXPLAIN**	Open one flagged app; point to score + 3 reasons.
01:30–02:30	**ACT**	Show category details and safe next steps.
02:30–03:00	**WRAP**	Restate privacy-first value and limitations.



DEMO • DON'T JUST TELL

THANK YOU

Safer apps.

Smarter decisions.

Make app access understandable.

Questions?

DETECT • EXPLAIN • EMPOWER

